CONFIDENTIAL - Calloway Metrics

Security Incident Postmortem: SEC-2026-014

Version v1.0 | Last updated Aug 14, 2026 | Owner: Kenji Torres (IC, SecEng) | Distribution: incident-sec-2026-014 list, Legal | Change note: final after counsel review

CONFIDENTIAL. Security Engineering. Incident SEC-2026-014, severity 1. Status: resolved. Author: Incident Commander, Security Engineering. This postmortem is privileged and prepared at the direction of counsel. Do not share outside the incident distribution list.

Summary. On July 28, 2026, between 02:14 and 05:51 UTC, an unauthorized party used a leaked service account token to read objects from a storage bucket named nw-prod-exports-eu. The bucket held scheduled CSV exports for 37 customers. Approximately 2.3 gigabytes of data was downloaded, including export files for Bramblewood Retail Group and Ostrander Mutual Insurance. No evidence of access to the primary warehouse or customer credentials was found.

Root cause. A long lived service account token for the export scheduler was committed to a public fork of an internal Helm chart by a contractor on July 19. The token had read access to every export bucket instead of being scoped per customer. Our secret scanning ran only on the main organization repositories and did not cover forks owned by personal accounts.

- 02:14 UTC: first anomalous ListObjects call from an IP address in a hosting provider range
- 03:02 UTC: data egress alert fires but is routed to a deprecated pager rotation
- 05:37 UTC: on call SRE notices egress graph during unrelated work and escalates
- 05:51 UTC: token revoked and bucket policy locked down
- July 29: forensic image captured, outside counsel engaged
- August 2: notifications sent to 37 affected customers

Impact. Thirty seven customers were notified. Two customers, Bramblewood and Ostrander, have requested contractual credits totaling 186,000 dollars. Legal assesses that EU data protection notification was required and it was filed within 72 hours. Exported files for 4 customers contained personal data of end users, approximately 41,000 records.

What went well. Once escalated, the token was revoked within 14 minutes. Access logs were complete because we had enabled object level logging in May. Customer communication was coordinated with legal and went out within five days.

What went poorly. The egress alert routed to a rotation that was retired in March. The contractor had standing access to production Helm values. Token lifetime was unlimited. Detection took 3 hours and 23 minutes.

Customer follow up. Each affected customer received a written incident report, a list of the specific export files accessed and the time window of access. Account directors held calls with all 37 customers within ten days. Two customers requested on site security reviews, which are scheduled for November.

Action items. Rotate all service account tokens to 12 hour workload identity credentials by September 30 (owner: Platform). Extend secret scanning to forks and contractor accounts (owner: Security). Scope export credentials per customer (owner: Data Platform). Audit all alert routes quarterly (owner: SRE). Remove contractor access to production values files (owner: IT). Status of these items is tracked in ticket SEC-ACT-221.

Document control and handling. This document is classified CONFIDENTIAL under the Calloway Metrics Information Classification Policy. It may be stored only in approved company systems and

must not be uploaded, pasted or summarized in external services, including consumer AI assistants, translation sites or personal email. Printed copies must be shredded after use. Report suspected disclosure to the Security team within one hour of discovery.